Compte rendu – Audit Active Directory (PingCastle)

TP réalisé dans le cadre du projet TSSR – environnement de laboratoire Windows Server 2016

Contexte et démarche

J'ai réalisé un audit de sécurité de mon contrôleur de domaine Active Directory à l'aide de l'outil PingCastle. Après génération du rapport, j'ai analysé les vulnérabilités identifiées et les ai classées en trois niveaux de criticité afin de prioriser les actions correctives.

Résultat global

Score obtenu : **Domain Risk Level 100 / 100** *(score maximum = niveau de sécurité le plus faible)*

Indicateur	Score	Règles déclenchées
Stale Objects (objets obsolètes)	100 / 100	13
Privileged Accounts (comptes privilégiés)	40 / 100	4
Trusts (relations d'approbation)	0 / 100	0
Anomalies (points de contrôle sécurité)	55 / 100	13

Vulnérabilités identifiées

Critiques – risque direct de compromission

- MS17-010 : faille EternalBlue non corrigée, permettant une prise de contrôle à distance du DC
- SMBv1 activé : protocole obsolète, vecteur d'attaque Man-in-the-Middle et ransomware
- NTLMv1 activé : protocole d'authentification faible, susceptible de relay attack
- Service Print Spooler actif sur le DC : exploitable via PrintNightmare (CVE-2021-34527)

Importantes – mauvaises pratiques à corriger

- LAPS absent : les mots de passe des comptes administrateurs locaux ne sont pas gérés automatiquement
- LLMNR activé : protocole de résolution de noms pouvant être détourné pour capturer des credentials
- Compte Administrateur intégré mal sécurisé (renommage et désactivation recommandés)
- Corbeille Active Directory non activée : impossibilité de restaurer des objets supprimés accidentellement
- Subnet non déclaré dans AD Sites & Services : peut perturber la localisation des DC par les clients

Mineures – optimisation

- Système d'exploitation non à jour (Windows Server 2016 sans tous les patchs)
- Configuration GPO incomplète ou non durcie

Plan de correction priorisé

Priorité	Action	Catégorie
1	Corriger MS17-010 (patch Windows)	Critique
1	Désactiver SMBv1	Critique
1	Désactiver le service Print Spooler sur le DC	Critique
2	Désactiver LLMNR	Importante
2	Déployer LAPS (gestion MDP admins locaux)	Importante
2	Sécuriser le compte Administrateur intégré	Importante
3	Activer la Corbeille Active Directory	Mineure
3	Déclarer le subnet dans AD Sites & Services	Mineure

Conclusion

L'audit met en évidence un environnement de laboratoire non durci, ce qui est attendu en contexte de TP. Les vulnérabilités identifiées sont réelles et leur correction suivra un plan structuré. La migration vers Windows Server 2019 constituera une étape supplémentaire d'amélioration de la sécurité du domaine.